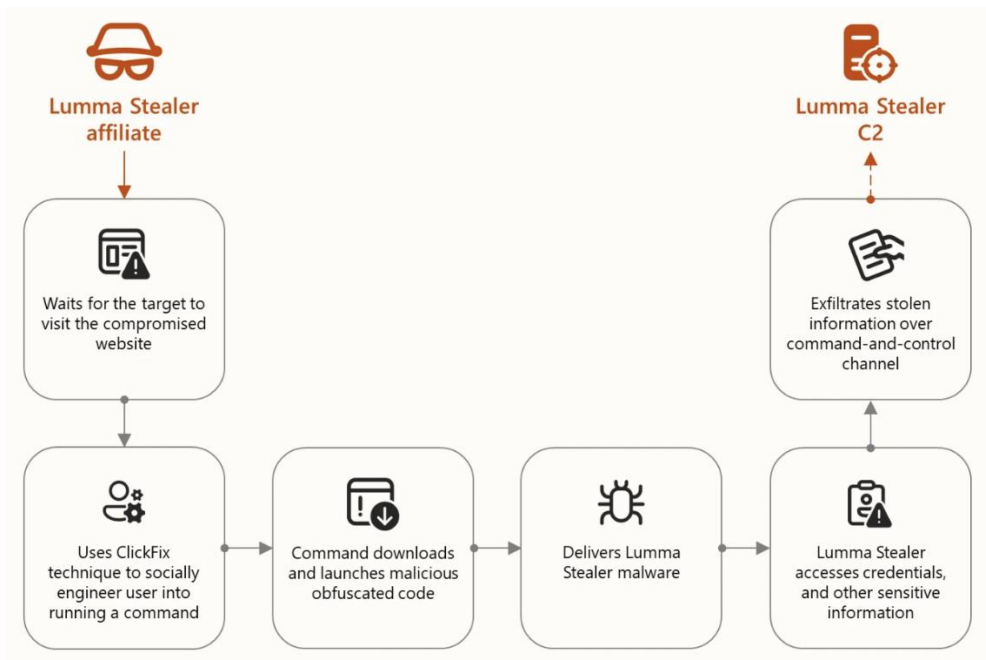


SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
Critical	Mar, 13, 2025, 09:44 AM	SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing	316	Data Leakage	>> ✓
EventID : 316 Event Time : Mar, 13, 2025, 09:44 AM Rule : SOC338 - Lumma Stealer - DLL Side-Loading via Click Fix Phishing Level : Security Analyst SMTP Address : 132.232.40.201 Source Address : update@windows-update.site Destination Address : dylan@letsdefend.io E-mail Subject : Upgrade your system to Windows 11 Pro for FREE Device Action : Allowed Trigger Reason : Redirected site contains a click fix type script for Lumma Stealer distribution. Show Hint ⓘ					

Lumma Stealer (aka LummaC2 Stealer) - a malware as a service (MaaS) offering that is capable of stealing data from various browsers and applications such as cryptocurrency wallets and installing other malware. Written in C language (<https://www.microsoft.com/en-us/security/blog/2025/05/21/lumma-stealer-breaking-down-the-delivery-techniques-and-capabilities-of-a-prolific-infostealer/>)



Dynamic Link Library (DLL) – module that contains functions and data that can be used by other modules

- helps promote the development of modular programs (reusability)

Phishing – cybercrime where attackers use messaging to deceive individuals to reveal sensitive information by pretending to be a legitimate source.

Data leakage - unauthorized disclosure or exposure of sensitive data to external parties (often accidental/ Unintentional)

- Data exfiltration = always intentional and malicious

1. Info about incoming email

Parse Email

Before starting the analysis, information about the incoming email should be obtained.

- When was it sent?
- What is the email's SMTP address?
- What is the sender address?
- What is the recipient address?
- Is the mail content suspicious?
- Are there any attachment?

Next

- When was it sent? **Mar 13, 2025, 09:44 AM**
- What is the email's SMTP address? **132.232.40.201**
 - IP address of the mail server that sent the email using SMTP
- What is the sender address? **update@windows-update.site**
- What is the recipient address? **dylan@letsdefend.io**
- Is the mail content suspicious? **YES**

-The recipient is directed to a different page/ site on clicking on the link than the one intended which suggests malicious intent.

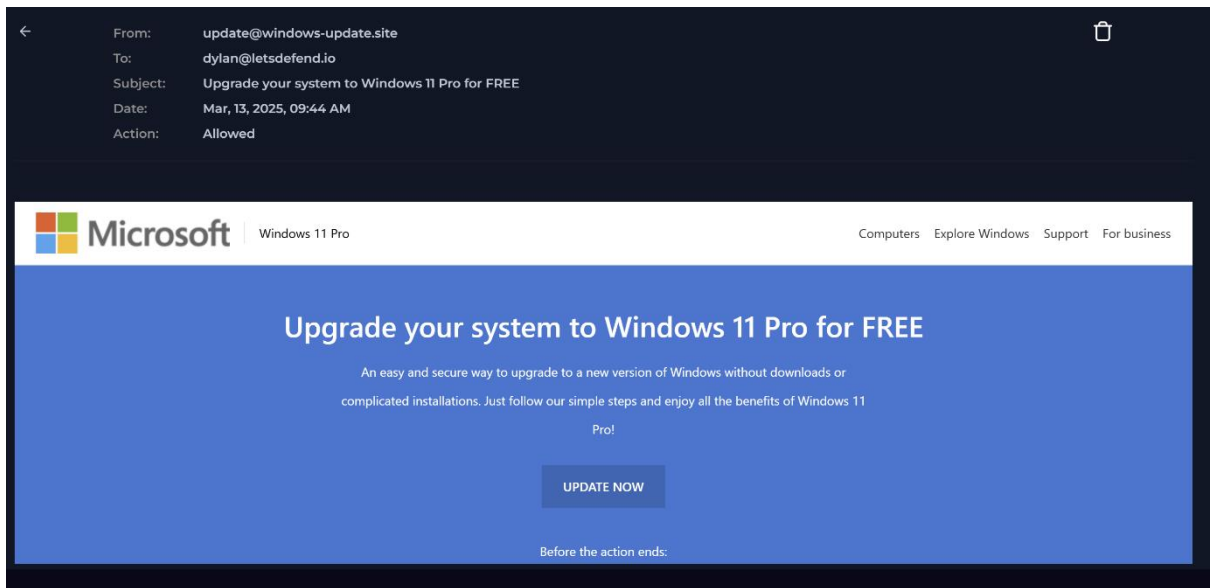
-Trigger Reason: Redirected site contains a click fix type script for Lumma Stealer distribution.

- Are there any attachment? **YES**

2. Url Attachments

There is clear indication to URL attachments as the email just redirects the user to a different page on clicking update now

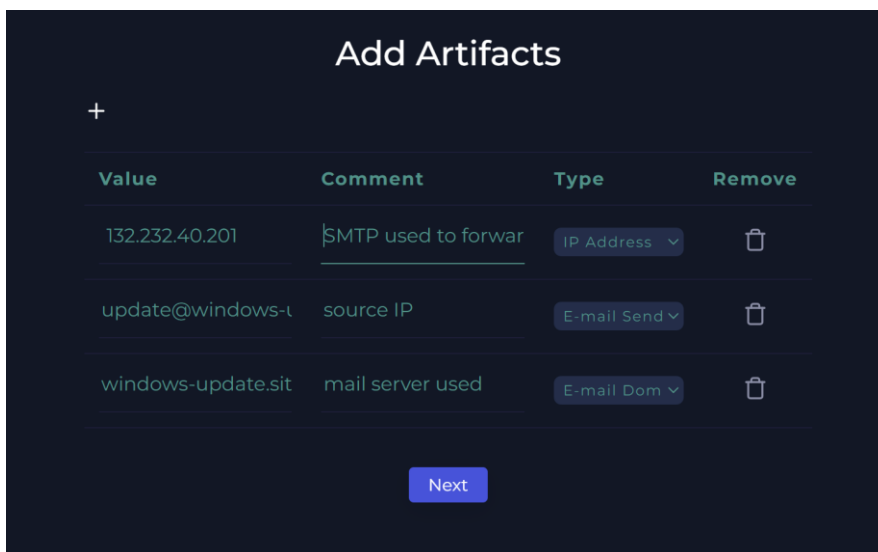
- This can be viewed using Email security



3. **Artifacts**

Evidence from the attack that can be used to verify extent of attack and help mitigate it.

- Email artifacts
- Network artifacts



Using these artifacts investigation can be done using log management and endpoint security

Log Management

Process of collecting, storing, analyzing, and monitoring log data generated by systems, applications, and devices in a network.

- Filter to easily locate the log details. For the results below I used the STMP address as the source address to filter out the results and since there is only one output there is no need for further filtration.

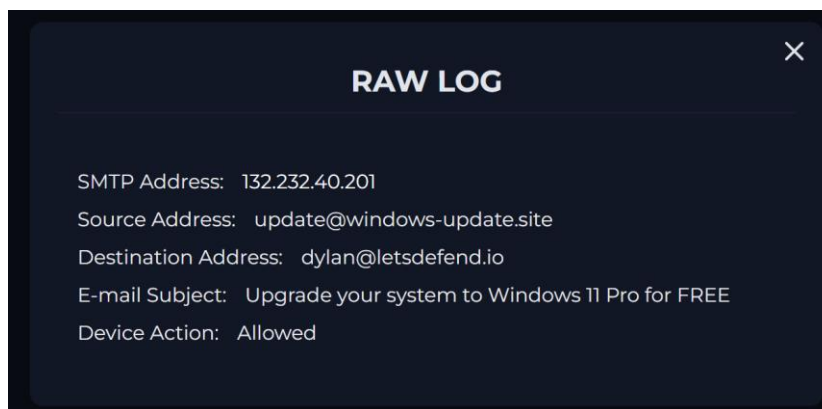
Show Filter					Search	
DATE	TYPE	SRC ADDRESS	SRC PORT	DEST. ADDRESS	DEST. PORT	RAW
Mar, 13, 2025, 09:44 AM	Exchange	132.232.40.201	23542	172.16.20.3	25	🔍

TYPE: Exchange = the event was logged from a Microsoft Exchange server or service

DEST PORT: 25 = standard port for STMP

SRC PORT: 23542 = randomly assigned port on the sender's system to open a connection

- i.e. TCP connections clients choose random port in range 1024-65535



SRC ADDR:132.232.40.201

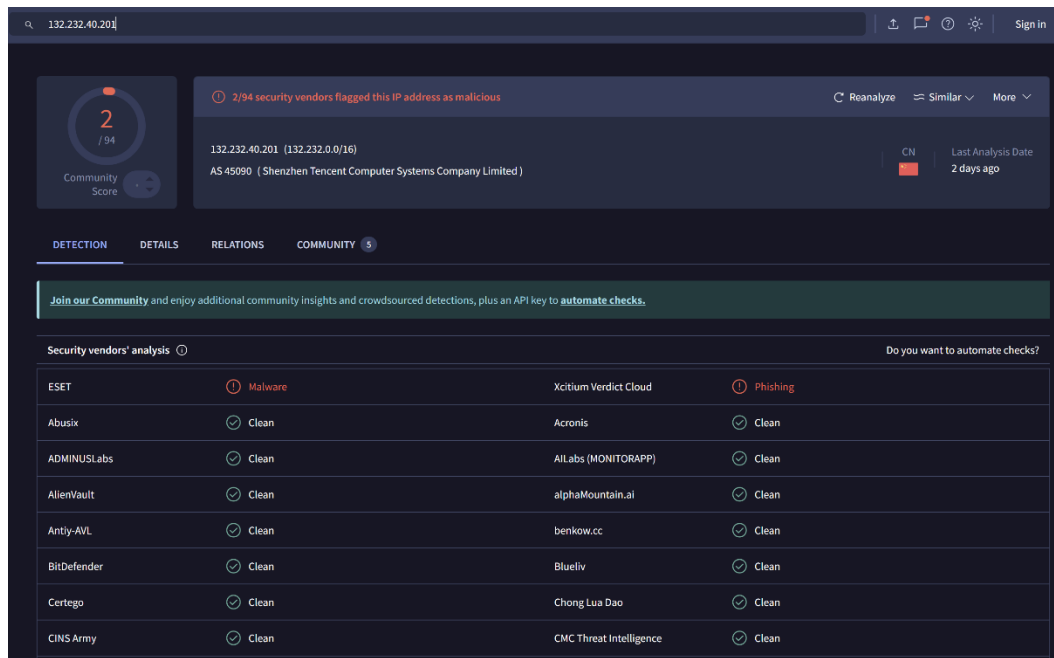
Source Address: update@windows-update.site

-To further prove that this address is malicious use 3rd party tools like

VirusTotal (<https://www.virustotal.com/gui/home/url>)

- Using this tool the ip address was flagged by the engine ESET as a malware/phishing

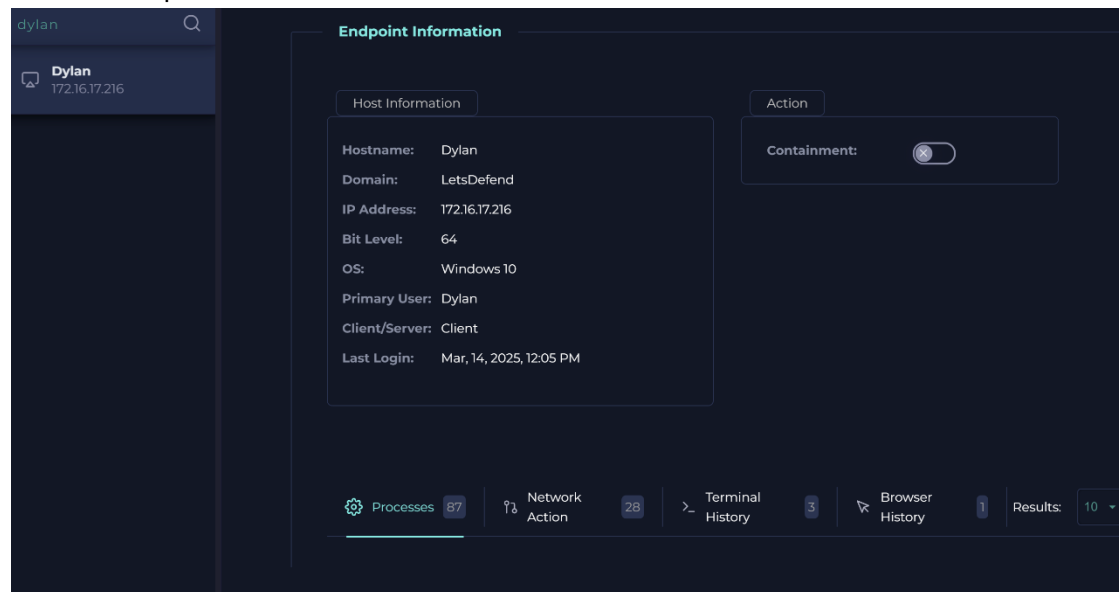
This validates the email as a threat and malicious.



Endpoint Security

Practice of protecting end-user devices from cyber threats.

- In this case the end user is the recipient address **dylan@letsdefend.io**
- From the log analysis we get the:
Destination address = 172.16.20.3
Destination port = 25



The above image shows the endpoint has not been contained thus may still be open to data leakage and C2 communication if the malware fully executes.



Processes

87



Network Action

28



Terminal History

3



Browser History

1

Results:

10



EVENT TIME

DESTINATION DOMAIN/IP ADDRESS

Mar 13 2025 23:26:08

132.232.40.201

The above only shows one instance of communication between the source Ip and the destination IP (Initial delivery)



Processes

87



Network Action

28



Terminal History

3



Browser History

1

Results:

10



EVENT TIME

DOMAIN NAME/URL

2025-03-13 23:26:08

https://windows-update.site/

<

1

>

Solution (mitigation):

- First is to immediately contain the host (Quarantine) to prevent further communication with malicious servers.

Action

Containment:

☒

Host Contained

- Follow up steps include patching the system as required
- Investigate for persistent mechanisms i.e the host becomes resource deprecated

4. Analysis Note

Analyst Note

Please enter your analysis comments.

The attack may still be active as the endpoint is not contained thus to mitigate it needs to be contained to stop/ avoid data leakage

133 / 3000

Next

5. Close the case

True positive – confirmed malicious email delivering Lumma Stealer